



UNIVERSITY OF MINES AND TECHNOLOGY, TARKWA
DEPARTMENT OF CYBERSECURITY AND INFORMATION SYSTEMS

PROJECT REPORT: LAB PROJECT 3

TITLE:

INFORMATION SECURITY PROJECT

Design and Implementation of an Organizational Information Security Framework

Submitted by: Enoch Nana Tabi Oduro

Student ID: FCM.41.018.197.23

CY3B | CY 380

Submission Date: 21 July 2026

TABLE OF CONTENTS

TABLE OF CONTENTS.....	2
SECTION 1: CASE BRIEF	3
1.1 Organization Profile.....	3
1.2 Business Services Overview.....	3
1.3 Organizational Structure.....	3
1.4 IT Infrastructure Overview	4
1.5 Nature of the Security Concern	4
1.6 Why AsedaHost Needs an Information Security Framework	5
SECTION 2: SECURITY AUDIT AND RISK ASSESSMENT REPORT	6
2.1 Audit Methodology	6
2.2 Identified Vulnerabilities.....	6
2.3 Threat Analysis	8
2.4 Roles and Responsibilities Analysis.....	8
3.1 Applicable Legal Frameworks.....	9
3.1.1 Ghana Data Protection Act 2012 (Act 843).....	9
3.1.2 Payment Card Industry Data Security Standard (PCI-DSS)	9
3.1.3 General Data Protection Regulation (GDPR)	9
3.1.4 Computer Crime Act 2008 (Act 772).....	9
3.2 Ethical Considerations.....	10
4.1 Acceptable Use Policy	10
4.2 Password and Authentication Policy	11
4.3 Access Control Policy.....	11
4.4 Data Classification and Handling Policy.....	11
4.5 Incident Reporting Policy	12
4.6 Security Roles and Responsibilities	12
5.1 Implementation Priority	15
6.1 Training Programme Overview	15
6.2 Training Tiers.....	16
6.3 Tier 1 Module Outline: Core Team (2 hours)	16
6.4 Tier 2 Module: Event Organizer Security Briefing (30 minutes).....	17
6.5 Quarterly Phishing Simulation Plan	17
6.6 Policy Acknowledgement Form	17
REFERENCES.....	18
Self-Declaration Statement on AI Usage and Academic Integrity	19

SECTION 1: CASE BRIEF

1.1 Organization Profile

Organization Name	AsedaHost
Legal Entity Type	Private Technology and Media Company
Nature of Business	Event hosting platform, digital voting, QR ticketing, and equipment rentals
Website	https://asedahost.com
Contact Email	info@asedahost.com
Phone Numbers	+233 55 163 5653 +233 53 538 5541
WhatsApp Support	+233 24 169 4276
Legal / DPO Contact	legal@asedahost.com
Built / Developed by	Erudite Africa Network (EAN)
Geographic Reach	Ghana-based, with Pan-African ambitions
Operating Hours	24/7 (platform-driven operations with WhatsApp live support)

1.2 Business Services Overview

AsedaHost operates as a multi-service event technology platform serving event organizers, academic institutions, and individuals across Ghana. Its core service lines are:

- **Digital Voting:** USSD-based voting via *714*707# and online voting through the web platform. Voters pay per vote (GHS 1.00 standard) and results are tracked on a live leaderboard. Revenue is shared with event organizers at an 11% platform commission.
- **QR Ticketing:** Instant QR code ticket generation and delivery via WhatsApp and SMS after payment. Tickets are verified at event entry.
- **Equipment Rentals:** Physical event equipment available for daily rental. Current inventory includes Starlink satellite internet units (GHS 350.00 per day). Rentals are managed through an online cart and scheduling system.
- **Event Gallery and Hall of Fame:** Public galleries of past events hosted on the platform, used for marketing and social proof.
- **Nominations and Event Analytics:** A host dashboard providing real-time analytics on ticket sales, voting revenue, nominee performance, and payout management.

1.3 Organizational Structure

AsedaHost is a lean, technology-driven startup. While the exact headcount is not publicly disclosed, the organizational functions map to the following roles based on platform operations and support channels:

Function	Estimated Staff / Role Count
Platform Development and Maintenance (EAN)	Technical development team (outsourced to Erudite Africa Network)
Operations and Event Onboarding	2 to 4 staff (event setup, organizer support)
Finance and Payments	1 to 2 staff (payout processing, Hubtel reconciliation)
Customer Support	1 to 2 staff (WhatsApp, email support, 24/7)
Management / Founders	1 to 2 principals

Given its startup profile, many roles overlap and a single staff member may handle operations across multiple functions. There is no evidence of a dedicated IT security officer or a formally appointed Data Protection Officer.

1.4 IT Infrastructure Overview

AsedaHost is an entirely cloud-native operation with no publicly documented on-premise servers. The following is inferred from the platform's technology stack, privacy policy, and observable features:

- **Web Platform:** A Laravel-based PHP web application hosted on cloud infrastructure. The frontend and backend serve event organizers, voters, and attendees at asedahost.com. The platform uses CSRF token protection (observed in page metadata), consistent with Laravel's built-in security features.
- **Payment Processing:** All financial transactions are routed through Hubtel, Ghana's leading licensed payment gateway. AsedaHost does not store card numbers or raw banking credentials. Payment channels include MTN Mobile Money, Telecel Cash, AT Money, and international debit/credit cards.
- **USSD Gateway:** Voting via *714*707# is delivered through a USSD short code integrated with the Hubtel telecommunications gateway, routing across all Ghanaian mobile networks.
- **Communication Channels:** WhatsApp Business API for customer support and ticket delivery. SMS gateway (via Hubtel or a third-party SMS provider) for ticket dispatch and vote confirmation.
- **Cloud Storage:** Event media, gallery images, and blog assets are stored in a cloud object storage bucket (evidenced by URLs such as asedahost.com/storage/blog/...).
- **Admin and Host Dashboard:** A web-based dashboard accessible to registered event organizers for real-time event management, payout requests, and analytics.
- **Authentication:** Login is available at asedahost.com/login. Password-based authentication is in use. No visible indication of enforced Multi-Factor Authentication for organizer or admin accounts.
- **Devices:** Staff likely operate on personal laptops and smartphones given the startup scale. No formal endpoint management policy is publicly documented.

1.5 Nature of the Security Concern

AsedaHost handles a growing volume of financially sensitive and personally identifiable data. The following security concern serves as the basis for this project, consistent with the phishing scenario described in the project brief:

A simulated security incident is posited: a platform operator received a spoofed email purportedly from Hubtel's support team, requesting urgent re-authentication of the payment gateway account due to a 'transaction anomaly'. The operator clicked the link and entered their Hubtel dashboard credentials on a fake page, potentially exposing payout settings, organizer wallet balances, and transaction histories. Although access was revoked within hours upon noticing an unknown device login, the incident revealed the following security gaps:

- No Multi-Factor Authentication enforced on organizer accounts or internal administrative logins.
- No email security gateway filtering inbound communications to staff.
- No formal incident response procedure for the team to follow.
- Staff awareness of phishing techniques is limited given the startup's early stage.
- No formal data classification, acceptable use, or access control policy exists in writing.
- The platform processes voter personal data (phone numbers, names, payment records) for thousands of users across events like NUGS-UMaT Excellence Awards, Miss UMaT 2026, and RENARSA-KNUST Dinner, without documented data retention and handling procedures.

1.6 Why AsedaHost Needs an Information Security Framework

- The platform collects and processes the personal data of voters and event attendees, including phone numbers, names, and mobile money transaction records, which fall squarely under Ghana's Data Protection Act 2012 (Act 843).
- Financial flows involving organizer payouts, voting revenue, and rental payments represent a high-value target for fraud and account takeover attacks.
- The USSD voting channel (*714*707#) is vulnerable to vote manipulation attempts if backend authentication and rate-limiting controls are not properly enforced.
- QR ticket delivery via WhatsApp and SMS creates spoofing and interception risks if communications are not authenticated.
- Rapid growth across Ghanaian universities and institutions (KNUST, UMaT, and others) means an increasing volume of user data processed per event cycle.
- The platform's own privacy policy references ISO 27001 readiness and PCI-DSS compliance as goals, indicating awareness of the need for a formal security framework but no evidence these have been fully achieved.
- As a platform built by Erudite Africa Network and relied on by institutional clients, a breach would damage trust with partner organizations and event organizers, with direct commercial consequences.

SECTION 2: SECURITY AUDIT AND RISK ASSESSMENT REPORT

2.1 Audit Methodology

The audit was conducted using the NIST SP 800-30 Risk Assessment Framework and referenced ISO/IEC 27001:2022 control categories. Given that AsedaHost is a real organization, data collection was based on: review of the publicly accessible website and platform features, the published Privacy Policy and Terms of Service, observable technology indicators (platform metadata, URL structures, payment integrations), and general startup profile analysis. No internal systems were accessed.

2.2 Identified Vulnerabilities

#	Vulnerability	Description	Affected Asset	Severity
V1	No Enforced MFA on Organizer Accounts	Login at asedahost.com/login appears password-only. A compromised organizer account exposes event revenue, payout settings, and attendee data.	Organizer dashboard, admin panel	Critical
V2	No Email Security Gateway for Staff	Internal staff communications are not protected by a formal email filtering or anti-phishing gateway, leaving staff susceptible to spoofed supplier emails (e.g., fake Hubtel notices).	Staff email accounts	Critical
V3	No Formal Incident Response Plan	No documented procedure exists for detecting, containing, or escalating a security incident, as evidenced by the absence of any published incident response policy.	Entire platform and team	High
V4	Limited Rate Limiting on USSD Voting	Without confirmed rate-limiting and anomaly detection on *714*707# vote submissions, coordinated vote manipulation or	USSD voting gateway, revenue integrity	High

#	Vulnerability	Description	Affected Asset	Severity
		financial fraud via mass dialing cannot be ruled out.		
V5	Unmanaged Personal Devices (BYOD)	A startup of this scale almost certainly relies on staff personal devices for operations and support. No mobile device management or endpoint policy is documented.	Internal communications, data access	High
V6	No Formally Appointed Data Protection Officer	The privacy policy references a DPO contact at legal@asedahost.com but does not confirm a named, formally appointed DPO as required under Ghana's Data Protection Act for data controllers.	Regulatory compliance	High
V7	Third-Party Risk: SMS and WhatsApp Delivery	QR tickets and vote confirmations are delivered via third-party channels. Interception or spoofing of these channels could allow ticket forgery or voter misdirection.	Ticketing system, voter communications	Medium
V8	No Documented Data Retention Schedule	The privacy policy states data is retained 'only as long as necessary' without specifying concrete timelines for voter PII, transaction records, or event attendee data.	User PII, financial records	Medium
V9	Cloud Storage Permissions (Media Assets)	Blog and event media stored at asedahost.com/storage/ is publicly accessible by URL. If storage bucket permissions are misconfigured,	Cloud object storage	Medium

#	Vulnerability	Description	Affected Asset	Severity
		sensitive files could be inadvertently exposed.		
V10	No Documented Security Awareness Training	No evidence of a formal security training program for staff or event organizers who have elevated platform access.	All platform users with admin/organizer roles	High

2.3 Threat Analysis

Threat	Likelihood	Impact	Risk Level	Related Vulnerability
Phishing targeting staff or organizers	High	Critical	CRITICAL	V1, V2, V10
Organizer account takeover	High	High	HIGH	V1, V5
Vote manipulation via USSD abuse	Medium	High	HIGH	V4
Financial fraud via fake payout requests	Medium	Critical	HIGH	V1, V3
Ticket forgery / QR spoofing	Medium	High	HIGH	V7
Data breach exposing voter PII	Low	Critical	HIGH	V8, V9
Regulatory sanction under Act 843	Medium	High	HIGH	V6, V8
Cloud storage misconfiguration exposure	Low	Medium	MEDIUM	V9

2.4 Roles and Responsibilities Analysis

AsedaHost currently lacks clearly defined information security roles. The following gaps were identified:

- No confirmed, named Data Protection Officer despite the platform's privacy policy referencing one by email address only.
- Technical responsibility for platform security appears to rest entirely with the development team at Erudite Africa Network, with no separation of duties or security governance at the business level.

- Event organizers, who have elevated access to attendee and financial data via the host dashboard, receive no documented security briefing or onboarding for data handling responsibilities.
- No documented escalation path exists for a security or payment incident, meaning response would be improvised rather than structured.

SECTION 3: LEGAL AND ETHICAL COMPLIANCE BRIEF

3.1 Applicable Legal Frameworks

3.1.1 Ghana Data Protection Act 2012 (Act 843)

AsedaHost collects and processes the personal data of voters, event attendees, and organizers, including phone numbers, names, and mobile money transaction records. As a data controller under Act 843, AsedaHost must:

- Register with the Data Protection Commission (DPC) of Ghana.
- Collect data only for specified, explicit, and legitimate purposes.
- Implement appropriate technical and organizational security measures to protect personal data.
- Notify the DPC and affected individuals in the event of a data breach.
- Appoint a formally designated Data Protection Officer with verifiable responsibilities, not merely a contact email.

The posited incident involving potential exposure of voter phone numbers and transaction records for events like Miss UMaT 2026 and NUGS-UMaT Excellence Awards would constitute a notifiable breach under Act 843. AsedaHost's current privacy policy acknowledges these obligations at a high level but lacks evidence of full operational compliance.

3.1.2 Payment Card Industry Data Security Standard (PCI-DSS)

AsedaHost accepts international debit and credit card payments through Hubtel. The platform's own privacy policy references PCI-DSS readiness as a goal. Since card processing is fully delegated to Hubtel (a licensed payment service provider), AsedaHost's direct PCI-DSS scope is reduced, but the organization still bears responsibility for the security of the environment that connects to the payment gateway, including the web application, API keys, and staff devices used to manage payout settings.

3.1.3 General Data Protection Regulation (GDPR)

AsedaHost describes itself as having Pan-African ambitions and accepts international card payments, suggesting potential engagement with users or organizers in the EU or UK. If personal data of EU-based individuals is processed, GDPR applies extraterritorially under Article 3(2). AsedaHost should audit its user base to determine whether GDPR applies and implement equivalent controls where it does.

3.1.4 Computer Crime Act 2008 (Act 772)

Unauthorized access to AsedaHost's admin panel, organizer accounts, or payment gateway credentials constitutes a computer crime under Act 772. Should AsedaHost suffer a confirmed

breach, it should consider preserving digital evidence (server logs, email headers, access records) and reporting to the Ghana Police Service Cybercrime Unit.

3.2 Ethical Considerations

Ethical Issue	Description	Recommended Approach
Voter Data Privacy	Voters share personal phone numbers and pay per vote. They expect their data to be used only for voting and not sold or profiled.	Commit to a strict data minimization policy. Retain vote-linked PII only as long as the event requires. Publish clear retention timelines.
Vote Integrity and Transparency	Paid voting creates an ethical tension: financially motivated voting could distort award outcomes and mislead the public.	Implement real-time anomaly detection to flag unusual voting bursts. Publish platform integrity policies visible to voters and organizers.
Organizer Access to Attendee Data	Event organizers can access attendee names and contact details through the host dashboard. This creates risk of unauthorized use of that data.	Restrict organizer access to data strictly necessary for attendance verification. Include data use terms in organizer agreements.
Transparency in Breach Disclosure	If a breach occurs, affected voters and organizers have a right to timely, honest notification.	Establish a breach notification SOP that includes direct communication to affected users within 72 hours of confirmation.

SECTION 4: INFORMATION SECURITY POLICY DOCUMENT

Document Reference: ISP-AH-001 | Version: 1.0 | Date: July 2026 | Owner: Management / DPO

This policy applies to all AsedaHost staff, contractors, event organizers with platform access, and any party acting on behalf of AsedaHost to access its systems, data, or infrastructure.

4.1 Acceptable Use Policy

- AsedaHost platform resources, including the admin panel, host dashboard, payment gateway integrations, and communication tools, are provided for legitimate business purposes only.
- Staff and organizers must not use platform access to view, export, or copy user data beyond what their role requires.
- Accessing AsedaHost systems from unsecured public Wi-Fi without a VPN is prohibited.
- Sharing login credentials for the admin panel, organizer dashboard, or Hubtel gateway with any third party is prohibited.
- All platform activity may be logged for security monitoring. Staff and organizers will be informed of this through the onboarding process.

4.2 Password and Authentication Policy

- All passwords for AsedaHost accounts (admin, organizer, payment gateway) must be a minimum of 12 characters, combining uppercase, lowercase, numbers, and special characters.
- Passwords must be unique across platforms. Reusing the same password for AsedaHost accounts and personal services is prohibited.
- Multi-Factor Authentication must be enabled on all admin accounts, organizer accounts with payout access, and any Hubtel gateway management credentials. This must be enforced at the system level, not left to individual discretion.
- The team must never request credentials from organizers or users by email, SMS, or phone. Any such request should be treated as a phishing attempt and reported immediately.
- A password manager (recommended: Bitwarden) must be used by all staff to manage and generate unique credentials.

4.3 Access Control Policy

- Access to platform systems is governed by Role-Based Access Control, granting each user the minimum permissions their function requires.
- New organizer accounts must be reviewed and approved before payout access is granted.
- Admin-level access must be reviewed every 90 days. Inactive accounts must be suspended or deleted.
- Third-party developers (including contractors at Erudite Africa Network) must access production systems only through a formally scoped agreement with time-limited credentials. No developer should retain permanent production admin access.

Role	Platform Admin Panel	Host Dashboard	Payment / Payout Settings
Voter / Attendee	No access	No access	Own transaction history only
Event Organizer	No access	Own events only	Own payout requests only
AsedaHost Support Staff	Read-only event data	All events (view only)	No access
Platform Administrator	Full access	Full access	Full access
EAN Developer (contractor)	Scoped, time-limited	No access	No access

4.4 Data Classification and Handling Policy

Classification	Examples	Handling Requirements	Storage
Confidential	Voter phone numbers, payout account details, organizer financial records, Hubtel API keys	Encrypted at rest and in transit (TLS 1.3). Accessible only to authorized roles. Not	Encrypted cloud database, secrets manager for API keys

Classification	Examples	Handling Requirements	Storage
		to be exported or shared without a formal data agreement.	
Internal	Event analytics, organizer communication, staff operational notes	For internal use only. Not to be shared with event organizers beyond their own event data.	Internal admin panel, staff communication tools
Public	Event listings, voting pages, gallery images, blog content	No restrictions on distribution.	Public-facing web platform, cloud storage bucket with public read permissions

- Hubtel API keys, USSD gateway credentials, and any third-party integration secrets must be stored in a secrets management tool (such as AWS Secrets Manager or HashiCorp Vault), never in source code or plain text configuration files.
- Voter PII must be retained for the duration of the event plus a maximum of 12 months for dispute resolution, then securely deleted.
- Transaction records must be retained for 7 years in line with Ghanaian tax and commercial regulations.

4.5 Incident Reporting Policy

- Any suspected security incident, including a phishing email, unauthorized account login, suspicious payout request, or platform anomaly, must be reported to the platform administrator within one hour of discovery.
- Staff and organizers must not attempt to investigate incidents themselves. They should report, document, and preserve evidence only.
- Confirmed breaches involving personal data must be reported to the DPC and affected individuals within 72 hours of confirmation, in line with Act 843 obligations.
- All incidents must be logged in a centralized Incident Register maintained by the platform administrator.
- The Hubtel payment team must be notified immediately in the event of any suspected compromise of gateway credentials or payout account details.

4.6 Security Roles and Responsibilities

Platform Owner / Management	Ultimate accountability for security. Approves policy, budget, and breach escalation decisions.
Data Protection Officer	Ensures compliance with Act 843. Oversees breach notification. Reviews data handling practices quarterly. Must be a formally named individual, not only a contact email address.

Platform Administrator	Enforces access controls. Monitors platform logs. Manages account provisioning and revocation. Coordinates incident response.
EAN Development Team	Responsible for implementing security controls in platform code: input validation, authentication, session management, and dependency security. Must follow secure development guidelines.
Event Organizers	Responsible for handling any attendee data accessed through the host dashboard in accordance with this policy and their signed organizer agreement.
All Staff	Must read and comply with this policy. Complete mandatory annual security awareness training. Report all suspected incidents promptly.

SECTION 5: SECURITY TOOLS RECOMMENDATION REPORT

The following tools are recommended based on their relevance to AsedaHost's cloud-native, startup-scale operating model, direct address of identified vulnerabilities, and feasibility of deployment for a lean team.

Tool	Category	Vulnerability Addressed	Cost Model	Justification
Google Workspace MFA or Authy for Business	Authentication	V1, V5	Free to low-cost	Enforces TOTP-based MFA on all staff and organizer accounts with elevated access. Eliminates the primary attack vector from the posited incident.
Bitwarden Teams	Password Management	V1, V5	Approx. \$3 per user per month	Centrally managed password vault preventing credential reuse across staff and third-party integrations. Audited open-source codebase.
Cloudflare Email Security (free tier)	Email Gateway / Anti-Phishing	V2	Free for basic / \$3 per user for advanced	Filters inbound staff email for phishing, spoofed senders, and malicious links. Enforces SPF, DKIM, and DMARC for the asedahost.com domain to prevent domain spoofing.

Tool	Category	Vulnerability Addressed	Cost Model	Justification
AWS Secrets Manager or Doppler	Secrets Management	V1, V4	AWS: ~\$0.40 per secret per month Doppler: free tier available	Stores Hubtel API keys, USSD gateway tokens, and database credentials securely. Prevents secrets from being hardcoded in source code or leaked via a repository.
Cloudflare WAF and Rate Limiting	Application and USSD Protection	V4, V9	Free tier available; Pro at \$20/month	Protects the web voting interface against automated vote manipulation, credential stuffing, and abuse. Rate-limits voting submissions per phone number per time window.
Wazuh (self-hosted or Wazuh Cloud)	SIEM and Monitoring	V3, V9	Free (self-hosted) or from \$50/month (cloud)	Centralizes platform access logs, alerts on anomalous login behavior, and provides real-time notifications for suspicious activity. Directly addresses the absence of an incident detection mechanism.
OWASP ZAP or Burp Suite Community	Vulnerability Scanning	V4, V9	Free	Used by the EAN development team to scan the platform for common web vulnerabilities (injection, broken auth, IDOR) before feature releases. Supports the ISO 27001 readiness goal.
1Password or Bitwarden (organizer onboarding)	Secure Credential Sharing	V1, V10	Free tier or included in Teams plan	Allows secure, auditable sharing of temporary access credentials with organizers during onboarding without exposing master account passwords.

5.1 Implementation Priority

Priority	Timeframe	Tools	Rationale
P1 - Critical	Week 1 to 2	MFA enforcement, Bitwarden, Cloudflare Email Security, SPF/DKIM/DMARC setup	Directly closes the attack vector from the phishing incident. Zero infrastructure cost for core items.
P2 - High	Week 3 to 4	AWS Secrets Manager (migrate Hubtel keys), Cloudflare WAF and rate limiting	Protects payment gateway credentials and voting revenue integrity.
P3 - Medium	Month 2	Wazuh monitoring, formal DPO appointment, data retention schedule	Builds detection capability and closes regulatory compliance gaps.
P4 - Ongoing	Quarterly	OWASP ZAP scans before each release, phishing simulation for staff	Maintains security posture as the platform grows and new features are added.

SECTION 6: USER AWARENESS AND TRAINING PLAN

6.1 Training Programme Overview

Programme Name	AsedaHost Security Awareness Programme (ASAP)
Target Audience	All staff, contractors, and event organizers with platform access
Delivery Mode	Short online modules (Google Classroom or Notion) and a recorded video walkthrough
Frequency	Mandatory at onboarding, annual refresher, quarterly phishing simulations
Responsible Party	Platform Administrator and DPO
Completion Tracking	Online module completion logs, signed policy acknowledgement form

6.2 Training Tiers

Tier	Target Group	Duration	Mode	Frequency
Tier 1: Core Team	All AsedaHost staff and EAN developers	2 hours	Online modules plus group session	Annual and at onboarding
Tier 2: Event Organizers	All registered organizers with dashboard access	30-minute self-paced module	Online video and checklist	At account approval
Tier 3: Platform Administrator	Admin and DPO	3-hour deep-dive workshop	In-person or video call with case studies	Annual
Phishing Simulation	All staff and admin-level organizers	Ongoing	Automated simulated phishing emails	Quarterly

6.3 Tier 1 Module Outline: Core Team (2 hours)

Module 1: Understanding the Threat Landscape for AsedaHost (25 minutes)

- What data AsedaHost holds and why it is a target: voter phone numbers, payout balances, organizer financial data
- The realistic threats: phishing impersonating Hubtel or MTN, account takeover, vote manipulation, fake payout requests
- Walk through the posited phishing incident and what it could have cost the platform

Module 2: Recognizing Phishing and Social Engineering (40 minutes)

- How to spot a spoofed email: sender domain discrepancies, urgency language, login links that do not match asedahost.com or hubtel.com
- What to do: do not click, do not enter credentials, report to the admin immediately
- Practical exercise: identify phishing versus legitimate emails in five sample scenarios
- The golden rule: Hubtel, MTN, and AsedaHost will never ask for your password by message or call

Module 3: Password and MFA Hygiene (20 minutes)

- Why password reuse is dangerous in a platform that handles live financial transactions
- Live walkthrough of setting up Bitwarden and generating a strong unique password
- Live walkthrough of enabling TOTP-based MFA on the admin account

Module 4: Handling Platform Data Responsibly (20 minutes)

- What counts as confidential data on the AsedaHost platform: voter PII, payout records, Hubtel API keys
- Where data must and must not be stored: no voter lists in WhatsApp chats, no API keys in GitHub
- How to respond if you accidentally expose sensitive data: report immediately, do not attempt to cover it up

Module 5: Incident Reporting (15 minutes)

- How to reach the platform administrator for a security report (contact details, WhatsApp, email)
- What counts as a reportable incident: suspicious logins, unexpected payout requests, phishing emails, lost devices
- Reporting in good faith carries no negative consequence

6.4 Tier 2 Module: Event Organizer Security Briefing (30 minutes)

- Your dashboard gives you access to attendee data. You are responsible for keeping it safe.
- Never share your login credentials with your team. Create separate accounts for co-organizers.
- Enable MFA on your organizer account before your event goes live. The platform will prompt you.
- Do not export or forward attendee lists to personal email or messaging apps.
- If you notice unexpected changes to your payout settings or nominee data, report it to AsedaHost support immediately via contact@asedahost.com.

6.5 Quarterly Phishing Simulation Plan

- Q1: Simulated email from 'Hubtel Support' requesting gateway re-authentication
- Q2: Simulated email from a fake 'organizer' requesting an urgent manual payout
- Q3: Spear-phishing using the recipient's name and a real upcoming event name
- Q4: Simulated SMS phishing (smishing) impersonating the USSD voting gateway
- Staff who engage with a simulation link are redirected to an educational page. Click-through rates are reviewed quarterly and trigger a re-briefing if rates remain high.

6.6 Policy Acknowledgement Form

To be signed by all staff at onboarding and annually thereafter:

I, _____, confirm that I have read and understood the AsedaHost Information Security Policy (ISP-AH-001). I agree to comply with all policies covering acceptable use, authentication, access control, data handling, and incident reporting. I understand that failure to comply may result in suspension of platform access or further disciplinary action.

Signature: _____ *Date:* _____

Role: _____ *Staff / Organizer ID:* _____

REFERENCES

1. Republic of Ghana (2012). Data Protection Act, 2012 (Act 843). Ghana Law Reform Commission.
2. Republic of Ghana (2008). Computer Crime Act, 2008 (Act 772). Parliament of Ghana.
3. European Union (2016). General Data Protection Regulation (GDPR), Regulation (EU) 2016/679. Official Journal of the European Union.
4. National Institute of Standards and Technology (2012). Guide for Conducting Risk Assessments, NIST SP 800-30 Rev. 1. U.S. Department of Commerce.
5. International Organization for Standardization (2022). ISO/IEC 27001:2022, Information Security Management Systems. ISO.
6. Payment Card Industry Security Standards Council (2022). PCI-DSS v4.0. PCI SSC.
7. AsedaHost (2026). Privacy Policy. <https://asedahost.com/privacy>
8. AsedaHost (2026). Terms of Service. <https://asedahost.com/terms>
9. Wazuh Inc. (2024). Wazuh Open Source Security Platform Documentation. <https://documentation.wazuh.com/>
10. Cloudflare (2024). Cloudflare Email Security and WAF Documentation. <https://developers.cloudflare.com/>
11. OWASP Foundation (2021). OWASP Top Ten. <https://owasp.org/www-project-top-ten/>
12. Hubtel (2024). Hubtel Payment Gateway Security Overview. <https://developers.hubtel.com/>

Self-Declaration Statement on AI Usage and Academic Integrity

I, **Enoch Nana Tabi Oduro** hereby declare that this project titled:
“Design and Implementation of an Organizational Information Security Framework” is
entirely my own original work.

I affirm that:

- I have **not used AI tools** (e.g., ChatGPT, Bard, or others) to generate full sections of this report.
- Any use of AI or digital tools was strictly limited to **grammar checks, formatting help, or idea prompts**, and **did not replace my personal understanding or effort**.
- I fully understand all the content presented in this project and can explain it independently if required.
- I have **not copied**, paraphrased, or submitted any material that I do not fully comprehend.

I understand that any false declaration, plagiarism, or excessive reliance on AI tools may result in **disqualification, failure, or disciplinary action**.

Student’s Name: Enoch Nana Tabi Oduro

Student ID: FCM.41.018.197.23

Signature: _____

Date: 21ST July, 2026